

FinElo - Resumo Técnico de Segurança e Arquitetura

Data: 08 de Dezembro de 2025 **Confidencialidade:** Uso Interno / Revisão de Stakeholders **Assunto:** Normas de Segurança, Conformidade e Proteção de Dados da Aplicação

1. Sumário Executivo

O FinElo é uma Single Page Application (SPA) moderna projetada para gestão financeira pessoal. A solução baseia-se em uma **Arquitetura Serverless** utilizando **Supabase** (Backend-as-a-Service) e **Vercel** (Hospedagem Frontend). Este documento descreve as medidas de segurança, estratégias de isolamento de dados e normas de conformidade implementadas para garantir a integridade dos dados e a privacidade do usuário, em conformidade com a LGPD.

2. Infraestrutura e Confiabilidade

A aplicação opera sobre provedores de infraestrutura de padrão industrial reconhecidos por certificações de segurança de alto nível (SOC2, HIPAA, ISO 27001).

- **Frontend:** Hospedado na **Vercel** (Global Edge Network), garantindo baixa latência e mitigação nativa de DDoS.
- **Banco de Dados e Auth:** Hospedados no **Supabase** (rodando sobre AWS/microserviços).
 - **Banco de Dados:** PostgreSQL 15+ (O banco de dados relacional open-source mais avançado do mundo).
 - **Backups:** Política de backups diários automatizados e Point-in-Time Recovery (PITR) fornecidos pela plataforma.
- **Criptografia:**
 - **Dados em Trânsito:** Todo o tráfego é criptografado via **SSL/TLS (HTTPS)**.
 - **Dados em Repouso:** Volumes de armazenamento são criptografados a nível de disco (AES-256).

3. Autenticação e Controle de Acesso

A gestão de identidade é realizada pelo **Supabase Auth** (baseado no servidor auditado GoTrue), desacoplando o manuseio de credenciais sensíveis do código da aplicação.

- **Hash de Senhas:** Senhas nunca são armazenadas em texto plano; utiliza-se hashing via **bcrypt** antes do armazenamento.
- **Autenticação por Token:** As sessões são gerenciadas através de **JWTs (JSON Web Tokens)** seguros e de curta duração.
- **Integração OAuth:** Suporte a login seguro via provedores Google e GitHub, utilizando fluxos padrão OAuth 2.0.

4. Isolamento de Dados (O Diferencial: RLS)

Diferente de aplicações web tradicionais que dependem de lógica de aplicação (ex: WHERE user_id = X) para filtrar dados — método propenso a falha humana — o FinElo utiliza **Row Level Security (RLS) do PostgreSQL**.

- **Segurança Profunda:** As políticas de segurança são aplicadas **diretamente no motor do banco de dados**, e não na camada de API.
- **Aplicação de Políticas:** Mesmo que um usuário mal-intencionado tente consultar a tabela "Transactions" diretamente via API, o banco retorna **zero linhas**, a menos que a requisição seja assinada com o JWT válido daquele usuário específico.
- **Políticas Estritas:**
 - SELECT: Usuários podem ler *apenas* registros onde user_id corresponde ao seu próprio ID.
 - INSERT: Usuários podem inserir *apenas* registros vinculados ao seu próprio ID.
 - DELETE/UPDATE: Restrito estritamente aos proprietários dos registros.

5. Privacidade e Conformidade (LGPD)

A arquitetura foi desenhada seguindo os princípios de "Privacy by Design".

- **Soberania dos Dados:** Cada usuário é o único proprietário e controlador dos seus dados financeiros.
- **Direito ao Esquecimento:** A aplicação inclui funcionalidade de "Excluir Conta" (Auto-Destruição) que executa um **Cascade Delete**. Mediante solicitação, o banco purga o registro do usuário e **todos** os dados associados (transações, orçamentos, logs) de forma instantânea e irreversível.
- **Coleta Mínima:** Coletamos apenas o estritamente necessário para o funcionamento (E-mail e User ID). Nenhuma PII (Informação Pessoalmente Identificável) desnecessária é armazenada.

6. Segurança da Aplicação (AppSec)

- **SQL Injection:** Imune por design devido ao uso de queries parametrizadas e interação via Supabase Client (ORM-like).
- **XSS (Cross-Site Scripting):** Mitigado pelos mecanismos automáticos de escape do React e Content Security Policy (CSP).
- **CSRF:** Gerenciado através de políticas de cookies SameSite para armazenamento de tokens de sessão.

7. Conclusão

O FinElo é construído sobre uma arquitetura "Guarded-Default" (Seguro por Padrão). A segurança não é um componente adicional, mas uma restrição fundamental imposta pela infraestrutura e pelo motor de banco de dados. Para a equipe de Data Tech, isso representa uma solução de baixo risco e alta conformidade, adequada para o ambiente corporativo e alinhada às exigências modernas de governança de dados.

Equipe de Desenvolvimento FinElo